

ANÁLISIS DE RIESGOS DE SEGURIDAD

Cajeros Automáticos (ATM)

Infraestructura Física, Tecnológica y Comunicaciones

Preparado por:

Kendall Montero

Especialista en Ciberseguridad

Vulnerabilidades | Blue Team | Pentesting | VMDR

Documento de uso confidencial — Mayo 2026

*Este documento es un análisis técnico independiente con fines informativos y de consultoría.
No sustituye una auditoría formal ni implica acceso autorizado a ningún sistema.*

Contenido:

1. Introducción	2
2. Perfil del Autor y Alcance del Análisis	3
3. Riesgos en la Dimensión Física	3
3.1 Transporte de Valores (CIT — Cash in Transit).....	3
3.2 Custodia y Reabastecimiento de Cajeros	3
3.3 Monitoreo de Sitio (Cámaras Perimetrales)	4
3.4 Respuesta a Alarmas	4
4. Riesgos en la Dimensión Tecnológica.....	5
4.1 Sistemas Anticlación de Tarjetas (Anti-Skimming).....	5
4.2 Comunicaciones entre el ATM y el Banco	5
4.3 Sistemas de Monitoreo Remoto del Estado del ATM.....	6
4.4 Alarmas de Vibración y Apertura No Autorizada	6
5. Matriz de Riesgos — Resumen Ejecutivo	7
6. Herramientas de Código Abierto para Auditoría	8
7. Marco Regulatorio Aplicable — PCI DSS y Otros	8
7.1 PCI DSS (Payment Card Industry Data Security Standard)	8
7.2 Otros Marcos Relevantes	9
8. Convergencia Física-Cibernética: El Diferenciador Estratégico.....	9
9. Glosario de Términos Técnicos.....	10
10. Conclusiones y Próximos Pasos	12

1. Introducción

Los cajeros automáticos (ATM) representan uno de los puntos de mayor concentración de riesgo en la infraestructura financiera global. Su función crítica es proporcionar acceso al efectivo a millones de personas y eso los convierte en objetivos permanentes tanto para ataques físicos como para amenazas digitales sofisticadas.

Este documento presenta un análisis integral de los vectores de riesgo que afectan a los ATMs, organizados en dos dimensiones: la dimensión física (transporte de valores, custodia, monitoreo perimetral y respuesta a incidentes) y la dimensión tecnológica (comunicaciones, sistemas anti-clonación, monitoreo remoto y control de acceso lógico). Además, se identifican las herramientas de código abierto disponibles para auditar estos entornos y se describen los marcos regulatorios aplicables, con énfasis en PCI DSS.

El objetivo de este análisis es ofrecer una visión técnica fundamentada que permita a los proveedores de seguridad física comprender el panorama completo de amenazas, identificar

brechas en sus operaciones actuales y explorar la convergencia entre seguridad física y ciberseguridad como diferenciador estratégico en el mercado.

2. Perfil del Autor y Alcance del Análisis

Nombre	Kendall Montero
Especialidad	Ciberseguridad: Gestión de Vulnerabilidades, Blue Team, Pentesting, VMDR
Herramientas	Qualys VMDR, Nmap, Wireshark, OpenVAS, Shodan, Metasploit, Burp Suite (entre otros)
Marcos de referencia	PCI DSS, ISO 27001, NIST CSF, CIS Controls
Alcance del documento	Análisis global de riesgos en ATMs físicos y tecnológicos con aplicabilidad regional

3. Riesgos en la Dimensión Física

La seguridad física de un cajero automático abarca todo el ciclo de vida operativo del dispositivo: desde el transporte de valores hasta la respuesta ante incidentes en tiempo real. A continuación, se detallan los cuatro vectores físicos principales y sus implicaciones de riesgo.

3.1 Transporte de Valores (CIT: Cash in Transit)

El traslado de efectivo entre bóvedas y cajeros es una de las operaciones de mayor exposición. Los equipos de CIT deben gestionar rutas, ventanas de tiempo, comunicaciones seguras y protocolos de respuesta ante interceptación.

Principales riesgos:

- Interceptación y asalto durante el traslado, especialmente en rutas predecibles o rutinas fijas.
- Compromisos internos: personal con acceso a rutas e información sensible puede actuar como facilitador.
- Fallos de comunicación entre el equipo de transporte y el centro de monitoreo.
- Ausencia de cifrado en las comunicaciones de despacho, permitiendo la escucha de frecuencias de radio.
- Falta de protocolos de verificación de identidad del personal receptor en el destino.

3.2 Custodia y Reabastecimiento de Cajeros

El proceso de carga y mantenimiento del ATM implica abrir el dispositivo en entornos públicos, lo que genera una ventana de vulnerabilidad física significativa.

Principales riesgos:

- Instalación de skimmers o dispositivos de interceptación durante la apertura del cajero.

- Sustitución de componentes internos (lectores de tarjeta, teclado PIN) por versiones modificadas.
- Acceso no autorizado al sistema operativo del ATM a través de puertos USB o de mantenimiento expuestos.
- Ataques Black Box: conexión directa al bus de comunicación interno para enviar comandos de dispensado.
- Personal de mantenimiento sin verificación biométrica o de doble factor de autenticación.

3.3 Monitoreo de Sitio (Cámaras Perimetrales)

Las cámaras de vigilancia alrededor del ATM son un componente crítico de disuasión y evidencia. Sin embargo, su implementación frecuentemente presenta vulnerabilidades significativas.

Principales riesgos:

- Cámaras IP con credenciales predeterminadas de fábrica (admin/admin o similares), accesibles remotamente.
- Firmware desactualizado en dispositivos de marcas como Hikvision, Dahua o Axis, con CVEs conocidos y públicos.
- Transmisión de video sin cifrar (protocolo RTSP sin autenticación) detectable con herramientas de red básicas.
- Ángulos muertos intencionales o accidentales que eliminan zonas de cobertura alrededor del dispositivo.
- DVRs y NVRs conectados directamente a internet sin segmentación de red, expuestos a búsquedas en Shodan.
- Ausencia de sistemas de detección de manipulación de cámara (lens tampering detection).

3.4 Respuesta a Alarmas

La eficacia del sistema de seguridad no depende solo de la detección, sino de la calidad y velocidad de la respuesta. Este es frecuentemente el eslabón más débil de la cadena.

Principales riesgos:

- Tiempos de respuesta excesivos que permiten la consumación del ataque antes de la intervención.
- Falsas alarmas frecuentes que generan fatiga operacional y reducen la atención del equipo de respuesta.
- Comunicación entre la central de monitoreo y el equipo de campo por canales no cifrados o inseguros.
- Ausencia de protocolos de escalamiento diferenciados por tipo de incidente (vibración, apertura, skimmer).
- Jamming de señal: dispositivos que bloquean las comunicaciones GSM/3G del cajero para deshabilitar alarmas remotas.

4. Riesgos en la Dimensión Tecnológica

Los ATMs modernos son computadoras especializadas ejecutando sistemas operativos conocidos (predominantemente Windows 7/10 en versiones embebidas), conectadas a redes bancarias mediante protocolos estándar. Esta realidad los expone a vectores de ataque propios del mundo digital.

4.1 Sistemas Anticlonación de Tarjetas (Anti-Skimming)

El skimming, es la captura fraudulenta de datos de tarjeta en el lector del ATM y sigue siendo uno de los fraudes más prevalentes a nivel global. Los sistemas anti-skimming buscan detectar o prevenir la instalación de dispositivos de interceptación.

Vectores de ataque conocidos:

- Skimmers de superposición (overlay): dispositivos que cubren el lector legítimo y capturan datos de la banda magnética.
- Shimming: láminas delgadas insertadas directamente en el slot de la tarjeta para interceptar datos de chip EMV.
- Captura de PIN mediante cámaras miniatura ocultas o teclados superpuestos.
- Skimmers inalámbricos con Bluetooth o GSM que transmiten datos capturados en tiempo real.
- Ataques a la interfaz de comunicación entre el lector de tarjeta y el núcleo del ATM (XFS/CEN).

4.2 Comunicaciones entre el ATM y el Banco

La comunicación entre el cajero y el servidor bancario es el canal por el que fluyen las transacciones financieras. Su integridad y confidencialidad son fundamentales.

Riesgos en el canal de comunicación:

- Uso de redes 3G/4G sin VPN configurada correctamente: el tráfico puede ser interceptado mediante ataques MITM con equipos IMSI Catcher (Stingray).
- Implementaciones de TLS con versiones obsoletas (TLS 1.0 o 1.1) vulnerables a ataques como POODLE o BEAST.
- Certificados digitales autofirmados o expirados que eliminan la validación de identidad del servidor.
- Protocolo ISO 8583 (estándar de mensajería financiera) sin capas adicionales de cifrado en implementaciones antiguas.
- Puntos de acceso WiFi falsos (Evil Twin) cerca del cajero que buscan capturar tráfico de administración.

Nota sobre redes 3G:

La conectividad 3G, aunque ampliamente utilizada en ATMs por su facilidad de despliegue, presenta limitaciones de seguridad estructurales. El protocolo SS7, es la base de las redes GSM/3G, y estas tienen vulnerabilidades conocidas que permiten la geolocalización, interceptación de llamadas y desvío de SMS sin conocimiento del operador ni del usuario.

4.3 Sistemas de Monitoreo Remoto del Estado del ATM

Los cajeros modernos reportan su estado operativo en tiempo real: niveles de efectivo, temperatura, estado de la impresora, eventos de error. Esta funcionalidad, si no está protegida correctamente, abre vectores de ataque significativos.

Riesgos del monitoreo remoto:

- Paneles de administración web accesibles sin autenticación fuerte o expuestos a internet.
- Uso de protocolos SNMP v1/v2c sin autenticación para la gestión remota, permitiendo lectura y escritura de configuración.
- Credenciales de acceso por defecto en software de gestión de fabricantes (Diebold, NCR, Nautilus Hyosung).
- Ausencia de segmentación entre la red de monitoreo y la red de transacción, permitiendo movimiento lateral.
- APIs de integración con sistemas bancarios sin autenticación OAuth o con tokens de larga duración sin rotación.

4.4 Alarmas de Vibración y Apertura No Autorizada

Los sensores físicos del ATM como: acelerómetros, sensores de apertura de gabinete, detectores de gas, son el último perímetro de defensa. Su comunicación hacia el centro de monitoreo es un vector frecuentemente ignorado.

Riesgos en el sistema de alarmas:

- Ataques de gas: uso de acetileno u oxígeno inyectado en el cajero para explosión controlada, diseñados para actuar antes de que la alarma de vibración se procese.
- Bloqueo de señal (jamming) GSM/3G en el área del cajero, dejando el dispositivo sin capacidad de comunicar alarmas.
- Manipulación del cableado de sensores para generar señales de estado normal falso (bypass físico).
- Ataques de replay: captura y reenvío de señales de estado para mantener reportando 'sin novedad' al centro de monitoreo.
- Ausencia de heartbeat autenticado: si el cajero deja de reportar, algunos centros no generan alerta automática.

5. Matriz de Riesgos — Resumen Ejecutivo

Vector de Riesgo	Nivel	Descripción / Impacto Principal
Transporte CIT sin monitoreo GPS cifrado	ALTO	Interceptación y asalto con información de ruta filtrada
Cámaras IP con credenciales default	ALTO	Acceso remoto no autorizado al sistema de vigilancia
Red 3G sin VPN + SS7 expuesto	ALTO	Intercepción de tráfico transaccional y bypass de alarmas
Skimming / Shimming en lector	ALTO	Robo masivo de datos de tarjeta y PIN de clientes
Black Box Attack en mantenimiento	ALTO	Dispensado fraudulento de efectivo sin registro
Jamming de señal GSM/3G	MEDIO-ALTO	Aislamiento del ATM del centro de monitoreo
Software de gestión sin parches	MEDIO-ALTO	Compromiso del sistema operativo del cajero
SNMP v1/v2 sin autenticación	MEDIO	Lectura y modificación de configuración remota
Ausencia de segmentación de red	MEDIO	Movimiento lateral hacia sistemas bancarios centrales
Firmware de cámara desactualizado	MEDIO	Ejecución remota de código en dispositivos de vigilancia
Falta de heartbeat autenticado	MEDIO	Ausencia de alertas cuando el cajero queda sin comunicación
TLS 1.0/1.1 en comunicaciones	MEDIO	Downgrade attack y descifrado de tráfico transaccional

6. Herramientas de Código Abierto para Auditoría

Las siguientes herramientas permiten realizar evaluaciones técnicas de la infraestructura asociada a ATMs, desde el reconocimiento de red hasta el análisis de comunicaciones y la gestión de vulnerabilidades. Todas son de código abierto o con versiones gratuitas funcionales.

Herramienta	Categoría	Aplicación en entornos ATM
Nmap	Reconocimiento	Descubrimiento de dispositivos en red del cajero: cámaras, DVRs, módems 3G, controladores de acceso
Wireshark	Análisis de tráfico	Captura y análisis del tráfico de red del ATM para detectar protocolos sin cifrar o credenciales expuestas
OpenVAS / Greenbone	Vulnerabilidades	Escaneo de vulnerabilidades en la infraestructura de red asociada: switches, servidores de monitoreo, endpoints
Shodan	OSINT / Reconocimiento	Identificación de cámaras, DVRs y sistemas de gestión expuestos públicamente por zona geográfica
Metasploit Framework	Pentesting	Validación de vulnerabilidades conocidas en sistemas Windows embebidos de ATMs y dispositivos de red
tcpdump	Análisis de tráfico	Captura ligera de paquetes en sistemas embebidos o puntos de red sin interfaz gráfica
SSLScan / testssl.sh	Criptografía	Análisis de la configuración TLS en comunicaciones del cajero: versiones, cifrados débiles, certificados
Aircrack-ng	Wireless	Evaluación de redes WiFi de administración o mantenimiento asociadas al cajero
Maltego (CE)	OSINT	Mapeo de relaciones entre entidades: empresas, dominios, IPs asociadas a operadores de ATMs
OWASP ZAP	Web / APIs	Análisis de paneles de administración web y APIs de integración de sistemas de monitoreo remoto
Nessus Essentials	Vulnerabilidades	Escaneo de vulnerabilidades gratuito (hasta 16 IPs) para evaluaciones de alcance limitado

7. Marco Regulatorio Aplicable — PCI DSS y Otros

7.1 PCI DSS (Payment Card Industry Data Security Standard)

PCI DSS es el estándar internacional de seguridad para cualquier organización que procese, almacene o transmita datos de tarjetas de pago. Todo cajero automático cae directamente dentro de su alcance, lo que lo convierte en el marco regulatorio más relevante para este análisis.

Requisitos PCI DSS directamente aplicables a ATMs:

- Req. 1 — Instalar y mantener controles de red: segmentación, firewalls entre la red del ATM y el resto.

- Req. 2 — No usar contraseñas predeterminadas del fabricante en ningún dispositivo de la infraestructura.
- Req. 4 — Cifrar la transmisión de datos de tarjeta sobre redes abiertas (incluye redes 3G/4G).
- Req. 6 — Gestionar el software con parches: aplica a sistemas operativos como Windows, Linux, Solaris/Unix, OS/2 Warp (IBM), MS-DOS embebido del cajero.
- Req. 9 — Controlar el acceso físico: quién abre el cajero, cuándo, con qué autorización y registro.
- Req. 10 — Registrar y monitorear todos los accesos: logs de transacciones, de acceso físico y de red.
- Req. 12 — Mantener una política de seguridad de la información para todo el personal con acceso.

7.2 Otros Marcos Relevantes

Marco	Aplicación en el contexto ATM
ISO 27001	Sistema de Gestión de Seguridad de la Información. Requerido por bancos multinacionales para sus proveedores de seguridad.
NIST CSF	Marco de ciberseguridad NIST. Proporciona estructura para Identificar, Proteger, Detectar, Responder y Recuperar.
CIS Controls	18 controles prioritarios. Los primeros 6 (inventario, configuración segura, vulnerabilidades) aplican directamente a la flota de ATMs.
Ley LFPDPPP (MX)	Ley Federal de Protección de Datos Personales (México). Las grabaciones de cámaras de cajeros contienen datos personales.
Ley 8968 (CR)	Ley de Protección de la Persona frente al Tratamiento de Datos Personales (Costa Rica). Misma aplicabilidad sobre grabaciones e información de clientes.

8. Convergencia Física-Cibernética: El Diferenciador Estratégico

La industria de seguridad física para cajeros automáticos ha operado históricamente como un mundo separado de la ciberseguridad. Sin embargo, la digitalización de los sistemas de monitoreo, la conectividad 3G/4G de los dispositivos y la integración con plataformas bancarias han creado un perímetro de riesgo convergente que ninguno de los dos campos puede gestionar de manera aislada.

Propuesta de valor de la seguridad convergente:

Capa 1 Hardening de Dispositivos	Capa 2 Monitoreo Continuo	Capa 3 Consultoría de Compliance
Configurar correctamente cámaras, NVRs y modems. Cambiar credenciales default, actualizar firmware, segmentar red.	Detectar si los sistemas del cliente están siendo atacados remotamente, antes de que el impacto sea visible.	Producir reportes de riesgo que los bancos clientes usen para PCI DSS e ISO 27001. Abrir conversaciones de auditoría.

Esta propuesta de valor es especialmente diferenciadora porque la mayoría de los proveedores de seguridad física en la región no cuentan con capacidades técnicas en ciberseguridad, y la mayoría de los consultores de ciberseguridad no comprenden las operaciones físicas de custodia y transporte. La intersección de ambos mundos es el espacio de mayor valor.

9. Glosario de Términos Técnicos

Este glosario está diseñado para facilitar la comprensión de los términos técnicos utilizados en este documento, sin requerir conocimientos previos en ciberseguridad.

Término	Definición
ATM	Cajero Automático (Automated Teller Machine). Dispositivo electrónico que permite a los clientes bancarios realizar retiros de efectivo, consultas de saldo y otras operaciones sin necesidad de personal.
CIT	Cash in Transit. Servicio especializado de transporte de valores (efectivo) entre bóvedas bancarias y cajeros automáticos, realizado por empresas de seguridad certificadas.
Skimmer / Skimming	Dispositivo fraudulento que se instala sobre el lector de tarjeta del cajero para capturar los datos de la banda magnética de la tarjeta sin que el usuario lo note.
Shimming	Variante del skimming donde se introduce una lámina delgada dentro del ranura de la tarjeta para interceptar los datos del chip EMV. Es más difícil de detectar visualmente.
Black Box Attack	Ataque donde el delincuente abre el gabinete del cajero y conecta un dispositivo externo directamente al cable que controla el dispensador de billetes, enviando comandos para forzar la entrega de efectivo.
MITM	Man in the Middle (Hombre en el Medio). Ataque donde un tercero intercepta la comunicación entre dos partes (ej. el cajero y el banco) sin que ninguna lo detecte.
VPN	Red Privada Virtual (Virtual Private Network). Tecnología que crea un canal cifrado sobre una red pública (como internet o 3G), protegiendo el contenido de las comunicaciones de cualquier interceptación.

TLS	Transport Layer Security. Protocolo criptográfico que cifra las comunicaciones en internet. Es el estándar actual de seguridad para transacciones financieras en red.
SSL	Secure Sockets Layer. Predecesor del TLS, hoy obsoleto y considerado inseguro. Algunos sistemas antiguos aún lo utilizan, lo que representa un riesgo.
PCI DSS	Payment Card Industry Data Security Standard. Conjunto de normas de seguridad obligatorias para toda empresa que procese, almacene o transmita datos de tarjetas de crédito o débito.
ISO 27001	Norma internacional para la gestión de la seguridad de la información. Proporciona un sistema estructurado de controles para proteger la información en las organizaciones.
NIST CSF	Marco de Ciberseguridad del Instituto Nacional de Estándares y Tecnología de EE.UU. Define cinco funciones: Identificar, Proteger, Detectar, Responder y Recuperar.
Firmware	Software de bajo nivel instalado permanentemente en un dispositivo electrónico (como una cámara de seguridad o un cajero). Si no se actualiza, puede contener vulnerabilidades explotables.
CVE	Common Vulnerabilities and Exposures. Registro público de vulnerabilidades de seguridad conocidas en software y hardware. Un CVE publicado indica que la falla es conocida y puede ser explotada.
SNMP	Simple Network Management Protocol. Protocolo para monitorear dispositivos en red. Las versiones v1 y v2c no tienen autenticación segura y permiten que terceros lean o modifiquen configuraciones.
Segmentación de red	Práctica de dividir una red en subredes separadas para evitar que un ataque en una zona se propague a otras. Esencial para aislar la red del cajero de sistemas bancarios críticos.
Pentesting	Prueba de penetración (Penetration Testing). Proceso controlado y autorizado de simular ataques reales para identificar vulnerabilidades en sistemas antes de que lo hagan los atacantes.
VMDR	Vulnerability Management, Detection and Response. Proceso integral de identificar, clasificar, priorizar y remediar vulnerabilidades en una infraestructura tecnológica.
Shodan	Motor de búsqueda especializado en dispositivos conectados a internet. Permite encontrar cámaras, cajeros, routers y otros dispositivos con configuraciones inseguras expuestos públicamente.
OSINT	Open Source Intelligence. Inteligencia obtenida a partir de fuentes públicas: internet, redes sociales, registros públicos. Se usa para investigar actores, organizaciones e infraestructuras.
Jamming	Interferencia deliberada de señales de radiofrecuencia (GSM, 3G, WiFi). En el contexto de ATMs, se usa para bloquear las alarmas del cajero y dejar al dispositivo sin capacidad de comunicar incidentes.
RTSP	Real Time Streaming Protocol. Protocolo usado por cámaras IP para transmitir video. Cuando no está protegido con contraseña o cifrado, cualquier persona en la red puede ver las grabaciones.

DVR / NVR	Digital Video Recorder / Network Video Recorder. Dispositivos que almacenan y gestionan las grabaciones de las cámaras de vigilancia. Son objetivos frecuentes de ataques por sus vulnerabilidades de firmware.
Heartbeat	Señal periódica que un sistema envía para indicar que está activo y funcionando correctamente. Si el cajero deja de enviar heartbeats, el centro de monitoreo debería generar una alerta automática.
EMV	Estándar internacional de tarjetas con chip (Europay, Mastercard, Visa). Reemplazó a la banda magnética para reducir el fraude. El shimming es un ataque específico contra este estándar.
SS7	Sistema de Señalización No. 7. Protocolo fundamental de las redes telefónicas GSM/3G. Tiene vulnerabilidades conocidas que permiten la interceptación de llamadas y localización de dispositivos.
XFS / CEN	eXtensions for Financial Services. Estándar de la industria para la comunicación entre el software del cajero y sus componentes físicos (dispensador, lector de tarjeta, teclado PIN). Es el objetivo de ataques como Black Box.
Blue Team	Equipo de seguridad defensivo dentro de una organización. Responsable de monitorear, detectar y responder a amenazas en tiempo real.
Compliance	Cumplimiento normativo. Proceso de alinear las operaciones de una organización con los requisitos de leyes, regulaciones o estándares del sector (ej. PCI DSS, ISO 27001).

10. Conclusiones y Próximos Pasos

Los cajeros automáticos representan uno de los entornos de mayor complejidad desde la perspectiva de seguridad, precisamente porque integran componentes físicos, tecnológicos y regulatorios en un único punto de operación. Un análisis que aborde solo la dimensión física o solo la tecnológica, deja brechas que los actores maliciosos explotan de manera rutinaria.

La convergencia entre la seguridad física operativa (CIT, custodia, respuesta a alarmas) y la ciberseguridad (evaluación de red, hardening, gestión de vulnerabilidades) no es una tendencia futura, es una necesidad presente que pocas empresas en la región han logrado implementar de manera cohesiva.

Pasos recomendados para una evaluación inicial:

1. Auditoría de red pasiva: identificar todos los dispositivos asociados a la operación del cajero (cámaras, DVRs, módems, switches) y su estado de exposición.
2. Evaluación de credenciales y firmware: verificar si los dispositivos usan credenciales por defecto y si el firmware está actualizado.
3. Análisis de comunicaciones: capturar y analizar el tráfico entre el cajero y la central para verificar la implementación correcta de TLS y VPN.
4. Gap analysis PCI DSS: mapear el estado actual de los controles frente a los 12 requisitos del estándar e identificar las brechas prioritarias.
5. Reporte ejecutivo: consolidar los hallazgos en un documento estructurado que el banco cliente pueda usar como evidencia de gestión de riesgo.

Este documento ha sido preparado por Kendall Montero como base para una conversación sobre la posibilidad de complementar operaciones de seguridad física con capacidades de ciberseguridad.

Especialista en Ciberseguridad | Vulnerabilidades, Pentesting y VMDR | Mayo 2026